

TÁI THIẾT KẾ HẠ TẦNG MẠNG DOANH NGHIỆP THEO MÔ HÌNH ZERO TRUST

THÔNG TIN ĐỀ TÀI

Tên đề tài: Thiết kế và triển khai giải pháp gia cố bảo mật mạng doanh nghiệp chống tấn công lan truyền (Lateral Movement) bằng OSPF Multi-Area và Extended ACL.

Bối cảnh:

Tập đoàn công nghệ TechVerse vừa đối mặt với một sự cố an ninh nghiêm trọng. Hệ thống Cảnh báo Xâm nhập (IDS) phát hiện một thiết bị Camera giám sát đặt tại Phân xưởng Sản xuất (IoT Zone) đã bị nhiễm mã độc (malware). Đáng báo động hơn, thiết bị này đang lén lút thực hiện hành vi dò quét mạng nội bộ (Network Scanning) trực tiếp vào khu vực lưu trữ cơ sở dữ liệu và kế toán nhạy cảm (Management Zone) của Công ty, đồng thời cố gắng thiết lập kết nối ra một máy chủ điều khiển (C&C Server) ẩn danh ở nước ngoài.

Sự kiện giống lên một hồi chuông cảnh tỉnh về một điểm yếu chí mạng lộ rõ của hạ tầng hiện hành: kiến trúc mạng cấp quyền cho các thiết bị kém an toàn (như camera cũ, sensor không mã hóa) giao tiếp quá tự do ngang hàng với các phân vùng máy chủ trọng yếu. Điều kiện lỗi thời mạng thiết kế cũ này đang mở toang cánh cửa cho kỹ thuật tấn công "Lan truyền ngang" (Lateral Movement) của Hacker.

Trước tình hình cấp bách, dự án tái cấu trúc toàn diện mạng lưới nhằm ứng cụ khẩn cấp chính thức được Ban Giám đốc khởi động. Yêu cầu bắt buộc là phải đập bỏ và thiết kế lại hạ tầng mạng phân tầng từ cấp độ định tuyến lõi (Routing Layer) đến kiểm soát quyền truy cập điểm (Access Control Layer) theo một triết lý an ninh duy nhất: **Zero Trust** ("Không bao giờ tin tưởng, luôn luôn xác minh").

Cơ sở lý luận và nguồn cảm hứng của Đề tài:

- Ý tưởng nền tảng:** Được lấy cảm hứng và mở rộng quy mô từ bài lab phân tích mạng của tạp chí công nghệ nổi tiếng PCWorld: "How to secure your router and home network". Yêu cầu bài lab mô phỏng việc "dịch" các khái niệm bảo mật gia đình cơ bản thành các công nghệ phức tạp tương đương vận hành ở cấp độ Doanh nghiệp (OSPF Totally Stubby Area, Access Control Lists, DMZ).
- Nền tảng kiến thức:**
 - Standard RFC 2328 định hình giao thức định tuyến động OSPF Version 2.
 - Các nguyên lý thiết kế mạng phân tầng chuẩn công nghiệp.
 - Triết lý bảo mật phòng thủ chiều sâu (Defense in Depth) và cấp quyền tối thiểu (Least Privilege).

I. Mục tiêu của đề tài

Đề tài hướng đến việc tái thiết kế và gia cố hạ tầng mạng doanh nghiệp (của tập đoàn mô phỏng TechVerse) theo mô hình bảo mật Zero Trust, nhằm cách ly triệt để các thiết bị không an toàn (IoT Zone) và ngăn chặn các cuộc tấn công lan truyền ngang (Lateral Movement), trong khi vẫn duy trì giao tiếp nghiệp vụ nội bộ thông suốt. Cụ thể, đề tài nhằm:

- Phân tích và xây dựng bài lab quy mô kiến trúc mạng doanh nghiệp phân tầng (Core, Distribution, Access) mô phỏng trên nền tảng mạng ảo (Mininet).
- Triển khai định tuyến động OSPF Multi-Area để kiểm soát thông lượng giữa các trung tâm dịch vụ. Cụ thể, hệ thống mạng được quy hoạch thành các vùng OSPF rõ ràng sau:
 - **Area 0 (Vùng Backbone/Core):** Trạm trung chuyển lõi gồm các thiết bị định tuyến trung tâm bảo đảm tốc độ truyền tải cao nhất.
 - **Area 10 (Vùng Inside / HQ Campus):** Mạng lưới văn phòng quản trị gồm VLAN Nhân viên thông thường (Staff) và VLAN Ban lãnh đạo/Kế toán mật (Management).
 - **Area 20 (Vùng DMZ / Data Center):** Vùng công cộng giới hạn, nơi đặt các máy chủ Internet-facing của công ty (Ví dụ: Web Server, Email Server hướng ra mạng Internet outside).
 - **Area 30 (Vùng IoT / Phân xưởng):** Mạng chứa thiết bị thông minh kém bảo mật (Camera giám sát, cảm biến) và được đặt ở trạng thái cô lập sâu nhất.
- Tối ưu hóa hiệu năng, bảo mật và khả năng chịu lỗi thông qua cơ chế dự phòng định tuyến (Failover) và khu vực vùng biên mù (Totally Stubby Area) chống lộ lộ thiết kế bảng định tuyến.
- **[Nâng cao]** Tăng cường an ninh cấu hình với mật mã xác thực (OSPF MD5 Authentication), bảo vệ toàn bộ phân đoạn định tuyến khỏi giả mạo gói tin.
- Phát triển hệ thống Access Control List (ACLs) toàn diện chuẩn Zero Trust (Defense in Depth) nhằm kiểm soát chặt chẽ luồng truy cập nội mạng và ngoại mạng.
- Đánh giá bảo mật thông qua việc xây dựng và triển khai các kịch bản mô phỏng kiểm thử thâm nhập giả định, phân tích khả năng phòng thủ, phát hiện và phản ứng của hệ thống trước nhiều tình huống tấn công khác nhau.

II. Nhiệm vụ cụ thể

Để đạt được các mục tiêu nêu trên, bài lab được chia thành các hạng mục nhiệm vụ cụ thể và theo trình tự như sau:

Phần A. Khảo sát và yêu cầu

- Thiết kế sơ đồ mạng tổng thể bao gồm các phân khu định tuyến: Core (Backbone), Campus HQ (Staff/Management), Data Center (DMZ) và Khu vực sản xuất (IoT Zone).
- Quy hoạch dải IP cho toàn bộ Router, Switch và các End-hosts, xác định rõ Router-ID cho các kết nối.

Phần B. Thiết kế hệ thống mạng

- Sử dụng nền tảng mạng mô phỏng Mininet và phần mềm định tuyến tiên tiến (FRRouting) để ảo hóa các trạm máy chủ định tuyến và trạm máy khách (Hosts).
- Thiết lập cấu trúc đầu nối vật lý thông qua Topology Python và gán địa chỉ IP trên các cổng giao tiếp mạng tương ứng.

Phần C. Cấu hình mạng định tuyến

- Kích hoạt giao thức OSPF Multi-Area, phân định vùng hoạt động Area tương thích và công bố định tuyến các Subnet tham gia vào mạng.
- Cấu hình cô lập IoT Zone bằng cách đặt vùng này giới hạn thành khu vực mù nội vùng Totally Stubby Area, che giấu các cấu trúc định tuyến chi tiết.
- Tính toán và định hình cấu trúc thuộc tính giao diện thông qua OSPF Cost cho phép hệ thống tự động nhận diện và chuyển đổi sang tuyến đường vòng dự phòng khi xảy ra sự cố.
- Kiểm tra sự hội tụ kết nối mạng Neighbor OSPF (FULL State) để đảm bảo độ tin cậy.

Phần D. Triển khai chính sách bảo mật

- Thiết lập Extended ACL trên các Router xung yếu để đảm bảo chính sách truy cập phân tầng an toàn:
 - *Cách ly IoT Zone*: Khóa chiều kết nối thiết bị IoT camera ra các phân khu nội mạng như Staff, DMZ, Management (Ngoại trừ cấp quyền bắt buộc: Syslog/Ping ra Internet).
 - *Bảo vệ DMZ Servers*: Chặn DMZ có hành vi chủ động liên kết xâm nhập ngược về vùng mạng campus inside.
 - *Phân quyền Internal Staff*: Từ chối các truy nhập nhân sự không nằm trong quyền hạn tham chiếu tới dữ liệu quan trọng của Management Zone.
- Đánh giá và kiểm duyệt bằng các kịch bản tương tác dữ liệu liên hệ đo lường khả năng ngăn chặn của lớp bảo vệ tường lửa ACL.

Phần E. Các nội dung nâng cao (để tìm hiểu thêm)

- **Xác thực định tuyến mã hóa**: Triển khai chứng thực OSPF MD5 Authentication trên toàn bộ miền trao đổi tuyến nhằm ngăn chặn rủi ro làm giả thông điệp thuật toán (LSA packet) giữa các Router.
- **Bảo vệ cổng kết nối từ xa cấp cao**: Cấm toàn bộ truy cập bằng giao thức Telnet rủi ro (clear-text data), và thiết lập giao thức đăng nhập lớp vỏ bảo mật an toàn SSH (Secure Shell).
- **Giới hạn Terminal Management**: Dựng Access Class chuyên biệt vào các line truy cập ảo (VTY Lines). Chỉ mở quyền Terminal cho bộ phận Admin PC.
- **Mã hóa điểm cuối**: Kích hoạt cơ sở mã hóa mật mã thiết bị nội bộ (`service password-encryption`).

III. Kết quả mong đợi

Sau khi hoàn thành các nội dung thiết kế, kiến trúc mạng bảo mật mong đợi đạt được các kết quả cụ thể:

1. Mô hình hạ tầng mạng doanh nghiệp mô phỏng

- Cấu trúc ảo hóa Mininet chạy ổn định thành công gồm trọn vẹn 6 điểm Routers trọng yếu và các thiết bị End-Hosts, sẵn sàng phục vụ kiểm thử theo các tiêu chí thực tế như mô hình mạng phần cứng.

2. Hệ thống mạng định tuyến OSPF tin cậy và linh hoạt

- Các node mạng trao đổi thông tin định tuyến (routes) thành công, đảm bảo giao tiếp trong toàn mạng.
- Bảng định tuyến của các thiết bị tại khu vực IoT Zone được che gọn chỉ dưới quyền kiểm soát của một Default Route nhờ cấu hình Totally Stubby Area.
- Thông lượng mạng tự động thay tuyến đường sao lưu một cách linh động ngay khi liên kết chính gặp trục trặc kỹ thuật.

3. Cơ chế an ninh mạng lưới hoạt động cứng rắn

- Chặn đứng hoàn toàn nguy cơ tấn công Lateral Movement (lan truyền ngang) xuất phát từ các thiết bị IoT bị kiểm soát.
- Đảm bảo tính khép kín và an toàn tuyệt đối cho khu vực lõi dữ liệu (Kế toán - Management) và các Server dịch vụ (DMZ). Chỉ đối tượng và luồng tin hợp lệ mới có quyền xâm nhập.

4. Tài liệu nghiên cứu và nghiệm thu hoàn thiện

- Toàn bộ cơ sở code (Scripts mạng/ Cấu hình thiết bị).
- Tài liệu báo cáo minh chứng cụ thể kết quả chạy test nghiệm thu gồm các bản ghi hoạt động OSPF và thông tin log lọc gói (packet filtering logs) từ Firewall ACL.

IV. Cấu trúc thư mục thư mục Bài lab (Mẫu tham khảo)

- Thư mục **src/**: Tổ chức các source code và script cấu hình mạng giả lập.
 - File **topology.py**: Script định nghĩa topology của hệ thống trực tiếp trên Mininet.
 - Thư mục **routers_config/**: Nơi lưu trữ cấu hình mạng rời của từng Router (như core_R1.conf, dmz_R2.conf).
 - Thư mục **acl_scripts/**: Tập hợp các file script Shell giúp triển khai quy tắc tường lửa (ví dụ block_iot.sh hay protect_management.sh).
- Thư mục **reports/**: Nơi chứa báo cáo hoàn thiện định dạng dạng PDF viết bằng Latex.

Lưu ý quan trọng: Bài lab không cung cấp sẵn mã nguồn Python (để dựng mô hình mạng) và không có mẫu thiết kế cấu hình sẵn. Các bạn cần tự nghiên cứu và xây dựng toàn bộ từ đầu để đạt được hiệu quả học tập tốt nhất.